

Security in 802.11 wireless networks



Wireless vs. cabled communications: Security issues

▷ Broadcast communication

- ♦ Hard to enforce physical propagation boundaries
- ♦ Typical physical boundaries are useless to avoid
 - Interference with communications
 - Eavesdropping of communications

▷ Mitigation

- ♦ Reduce interference and eavesdropping capabilities
 - At the data link layer

Reduce interference and eavesdropping capabilities: data layer

- ▷ Prevent attackers from identifying the participants in a communication
 - ♦ Randomized MAC addresses
- ▷ Prevent eavesdroppers from understanding data link payloads
 - ♦ Encryption of frames' payloads
 - ♦ Usually, payloads only are encrypted
- ▷ Prevent attackers from forging acceptable data link frames
 - ♦ Frames need to be authenticated
 - ♦ Origin authentication
 - ♦ Freshness

IEEE 802.11:

Architecture (in structured networks)

▷ Station (STA)

- ◆ Device that can connect to a wireless network
- ◆ Has a (unique) identifier
 - Media Access Control (MAC) address
 - Today it is becoming popular its randomization (for anonymity sake)

▷ Access Point (AP)

- ◆ Device that allows the interconnection between a wireless network and other network devices or networks

▷ Wireless network

- ◆ Network formed by a set of STAs and AP that communicate using radio signals

IEEE 802.11:

Structured network terminology

▷ Basic Service Set (BSS)

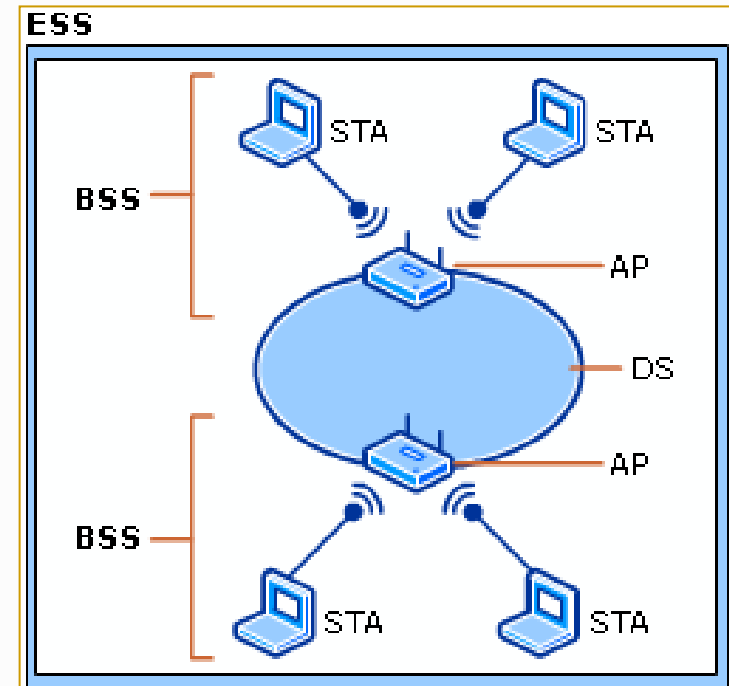
- ◆ Network formed by a set of STA associated to an AP

▷ Extended Service Set (ESS)

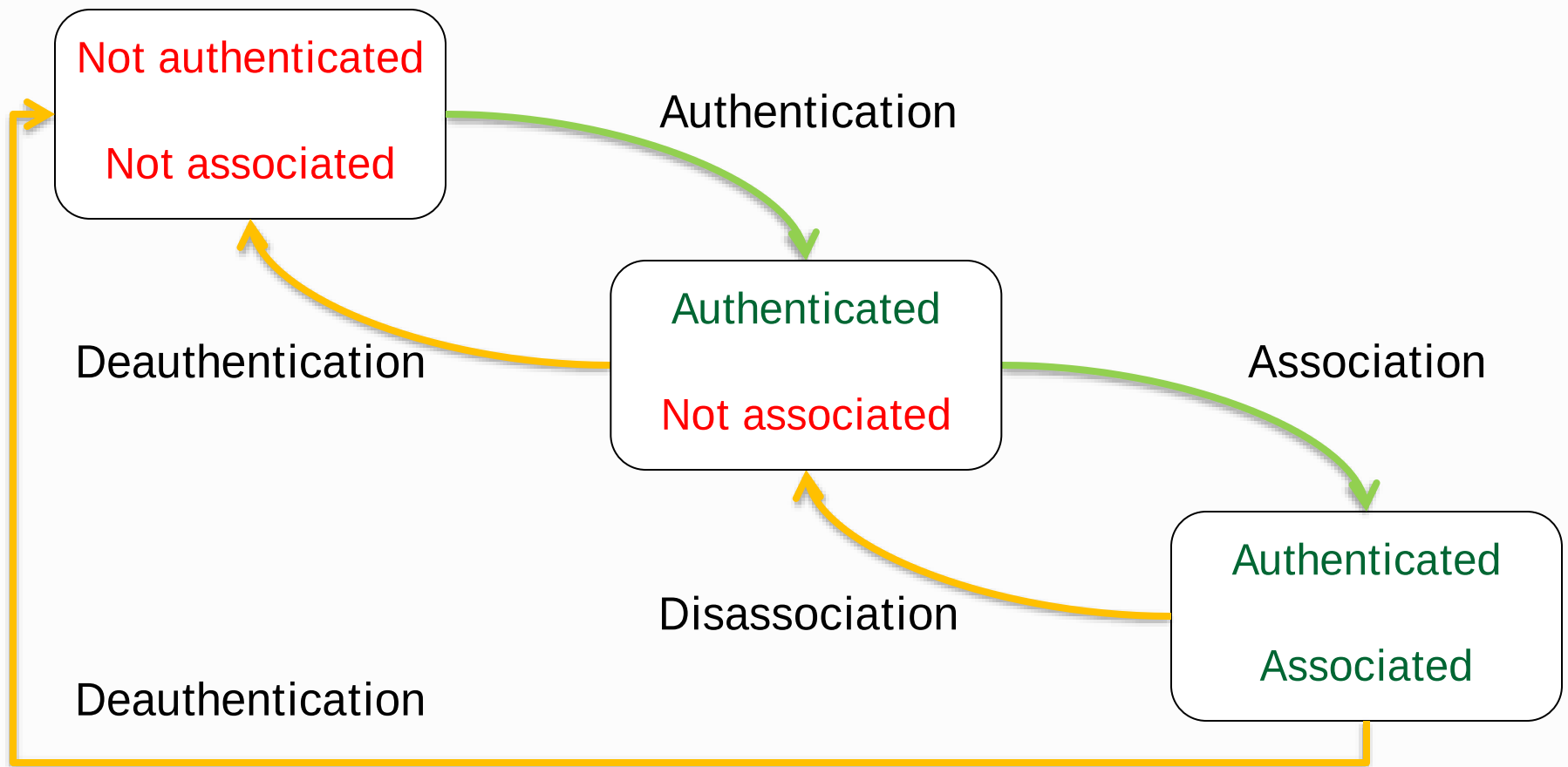
- ◆ Network formed by several BSS interconnected by a Distribution System (DS)

▷ Service Set ID (SSID)

- ◆ Identifier of a wireless network served by a BSS or ESS
- ◆ The same infrastructure can use several SSID



IEEE 802.11: Authentication & Association state machine



IEEE 802.11: Frame types

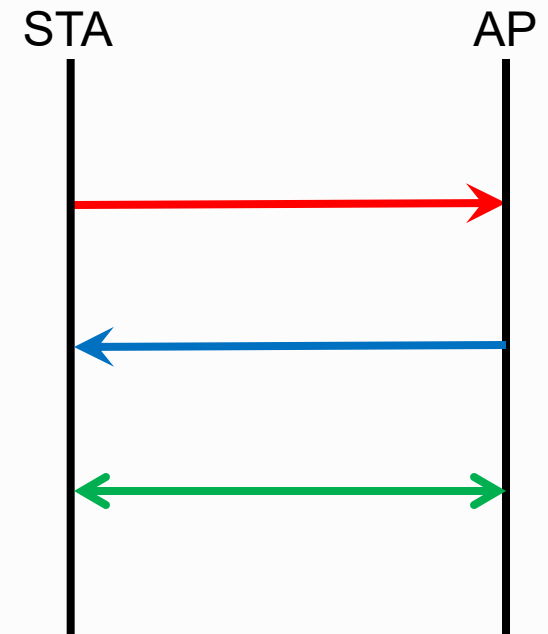
▷ Management frames

- ♦ Beacon
- ♦ Probe Request & Response
- ♦ Authentication Request & Response
- ♦ Deauthentication
- ♦ Association Request & Response
- ♦ Reassociation Request & Response
- ♦ Disassociation

▷ Control frames

- ♦ Request to Send (RTS)
- ♦ Clear to Send (CTS)
- ♦ Acknowledgment (ACK)

▷ Data Frames



IEEE 802.11 data link security:

Overview

Network Type		pre-RSN	RSN (Robust Security Network)	
Functionality		WEP	WPA	802.11i (ou WPA2)
Authentication		Unilateral (STA)	Bilateral with 802.1X (STA, AP and network)	
Key Distribution			EAP ou PSK, 4-Way Handshake	
IV Management Policy			TKIP	AES-CCMP
Data Cipher			RC4	AES-CTR
Integrity Control	Headers		Michael	AES
	Payload	CRC-32	CRC-32, Michael	CBC-MAC

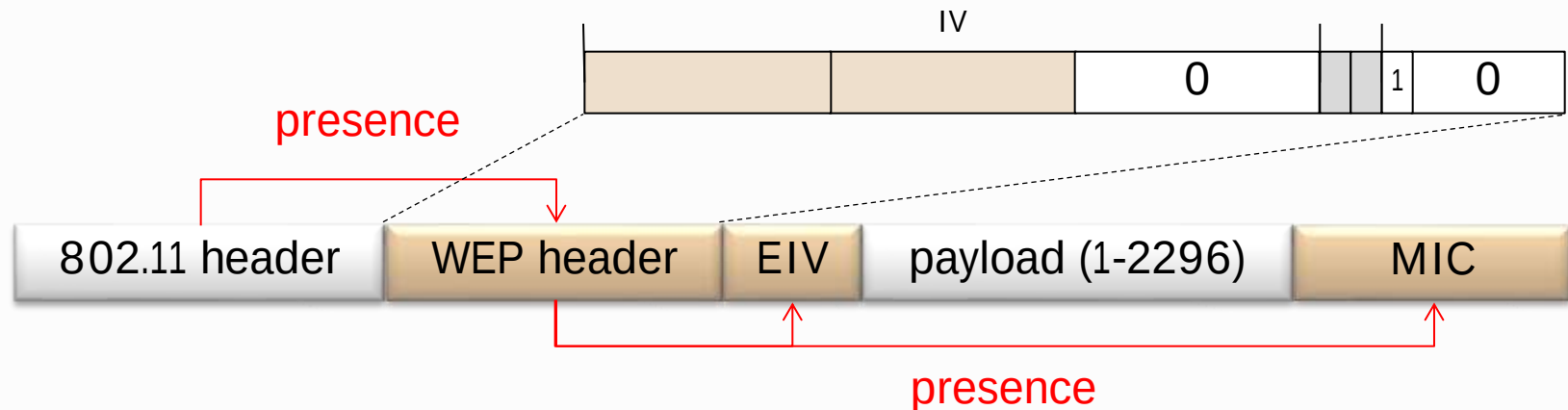
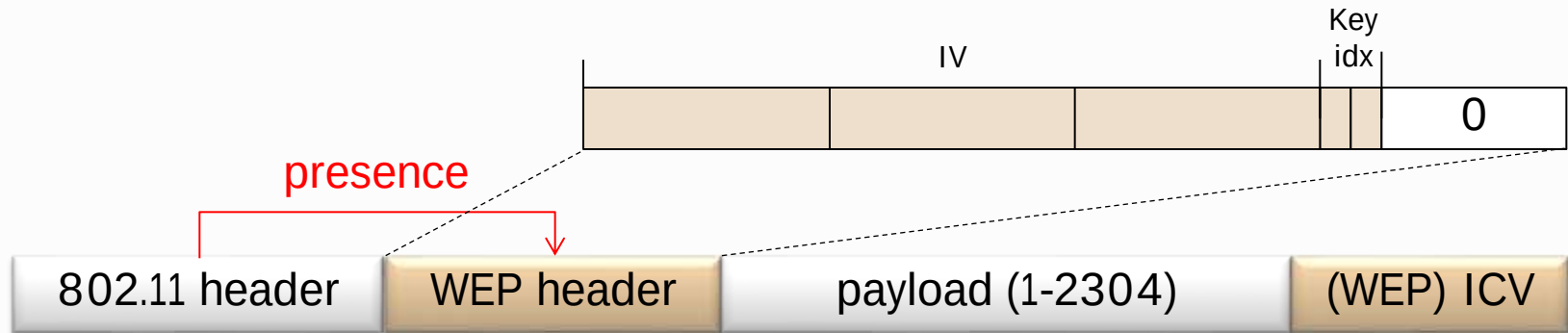
► Other

- ♦ SSID hiding (on beacons)
- ♦ MAC address filtering (on associations)
- ♦ (Privacy) MAC client randomization before association

IEEE 802.11i (WPA2)

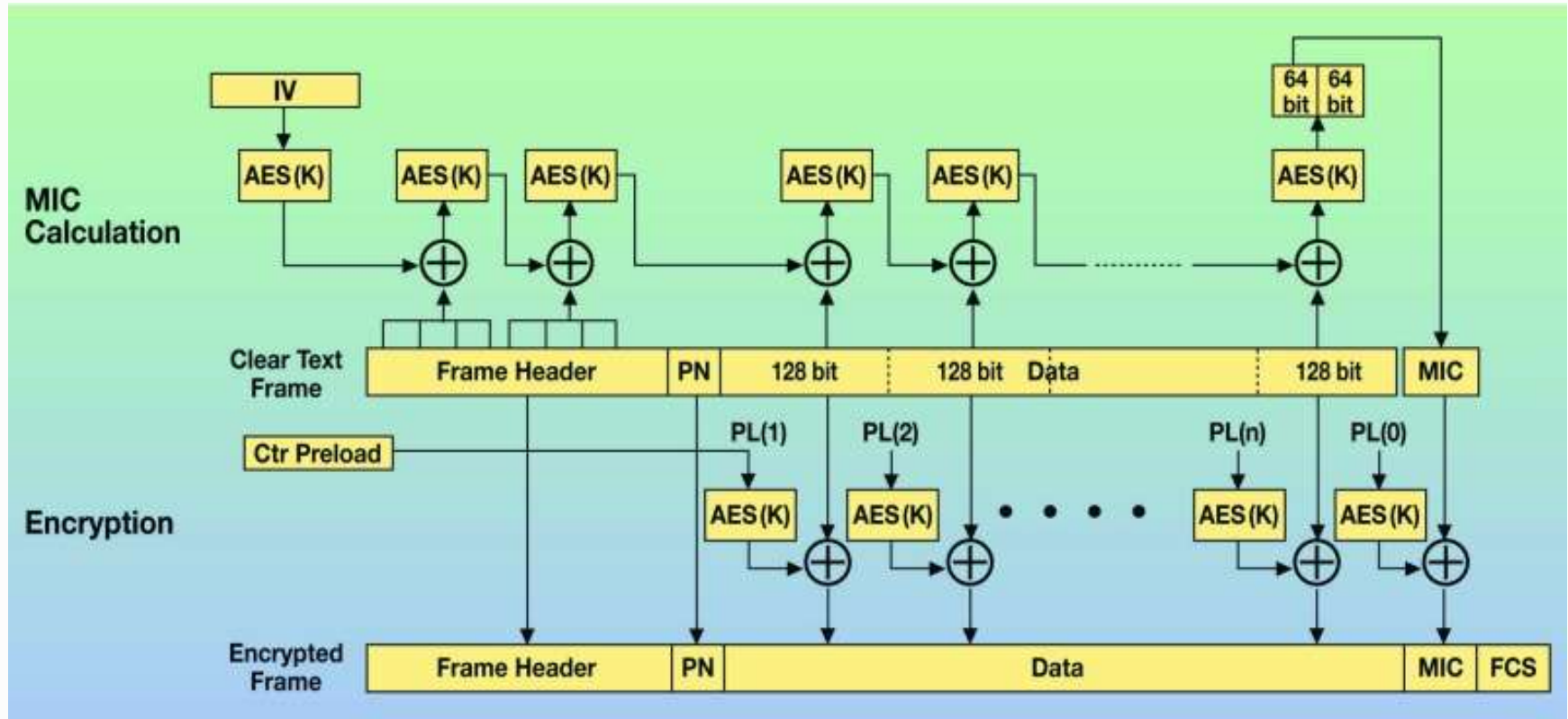
- ▷ Defines Robust Security Networks (RSN)
 - ◆ Those that support WPA and 802.11i
- ▷ Uses advanced security mechanisms for frame protection
 - ◆ Advanced Security Algorithm (AES) for payload encryption and frame integrity control
- ▷ Uses 802.1X for network access authentication
 - ◆ Simplified Pre-Shared Key (PSK) mode for SOHO (Small Office, Home Office) environments
 - ◆ EAP-based protocol for enterprise environments

WEP vs AES-CCMP: Frame layout



WPA2 frame protection

- ▷ AES CCMP – AES Counter Mode CBC-MAC Protocol
 - ♦ 128-bit keys, protection of headers, data, with cipher and authentication

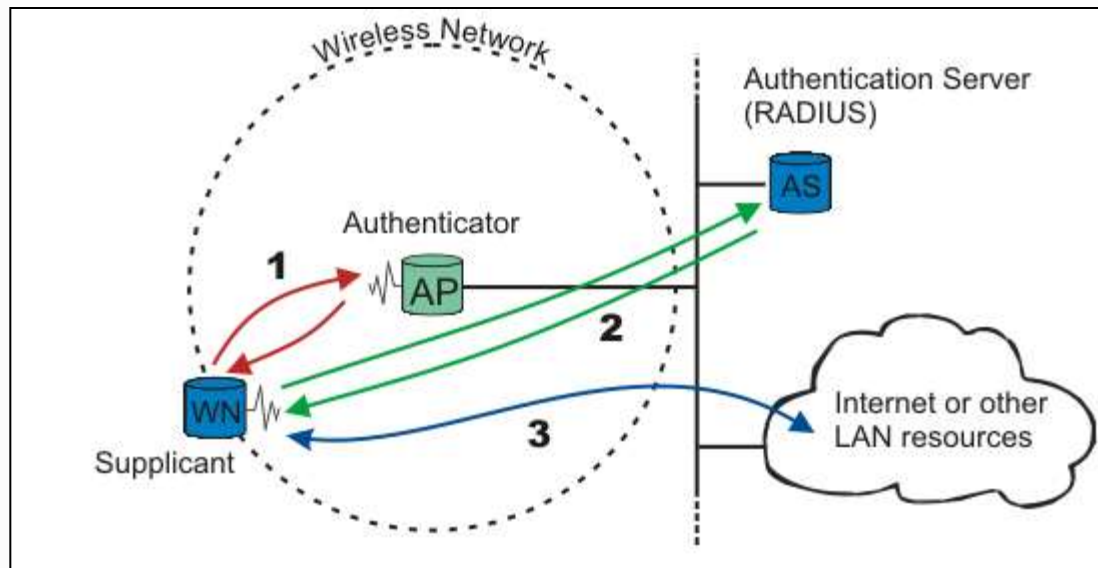
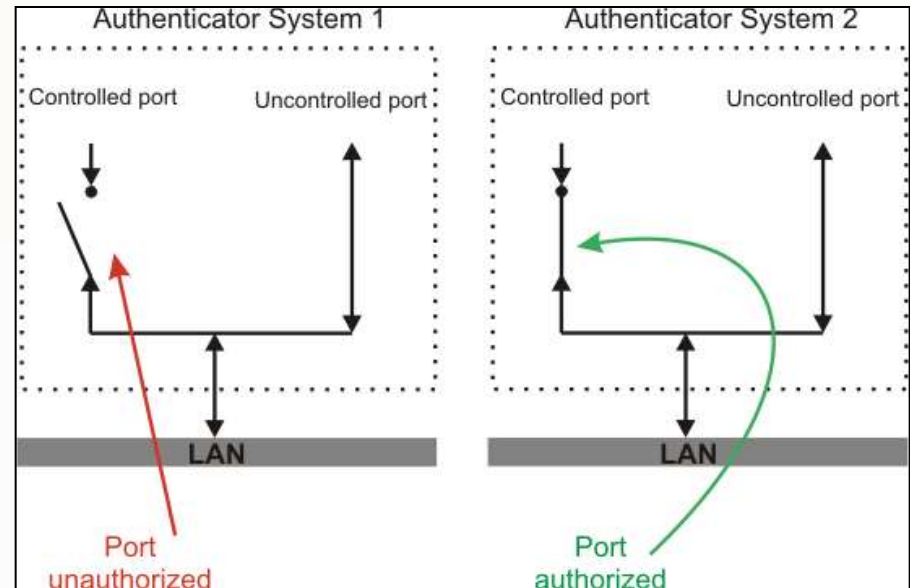


IEEE 802.1X:

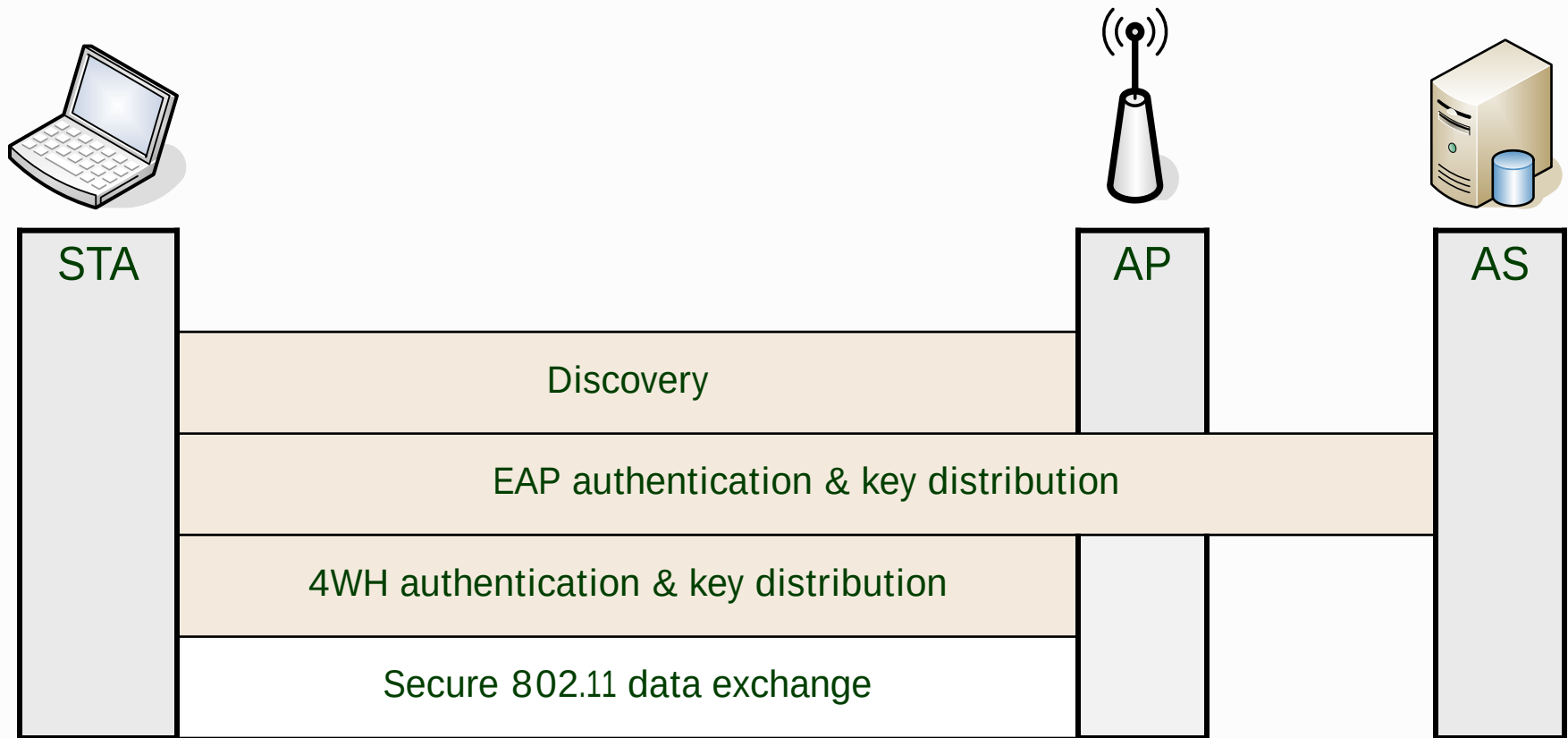
Port-Based Authentication

- ▷ Authentication model for all IEEE 802 networks
 - ♦ Layer 2 mutual authentication
- ▷ Originally conceived for large networks
 - ♦ University campus, etc.
 - ♦ Model was extended for wireless networks
- ▷ Performs key distribution
 - ♦ Additional protocols focus in the remaining processes

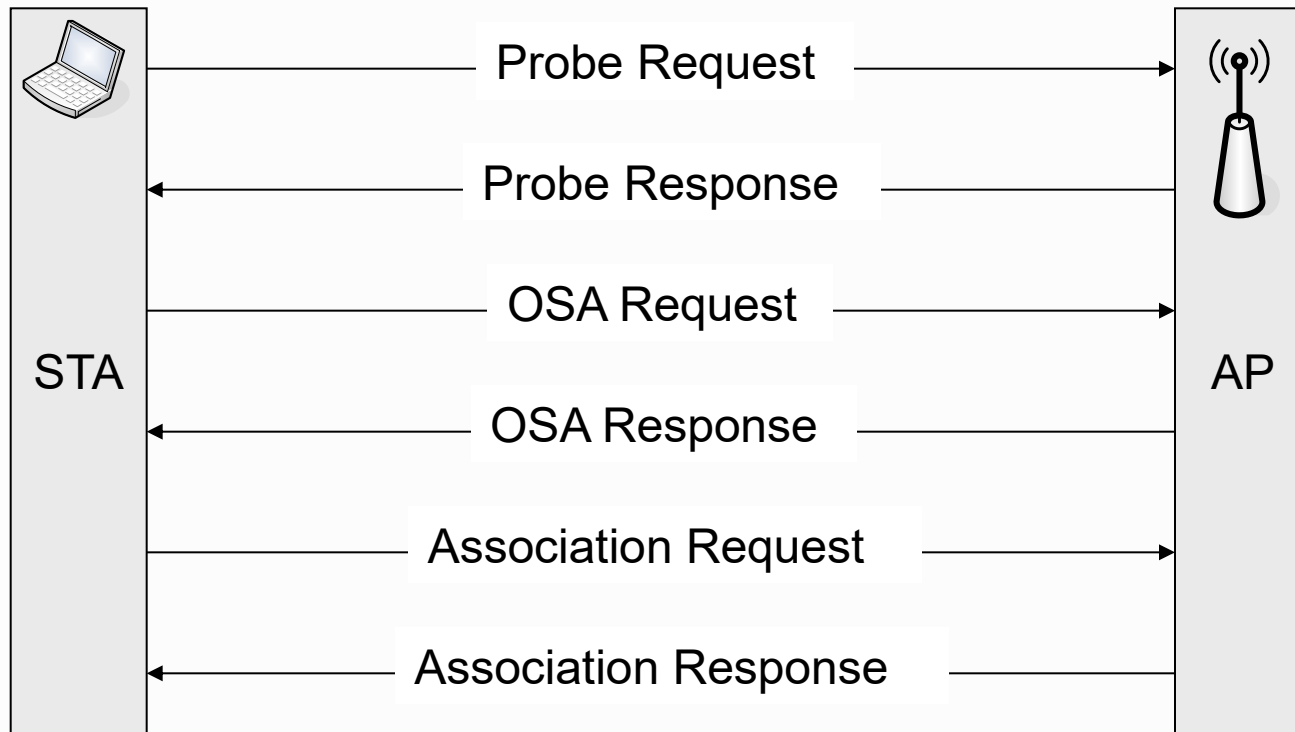
IEEE 802.1X: Architecture



IEEE 802.1X: Operational Phases



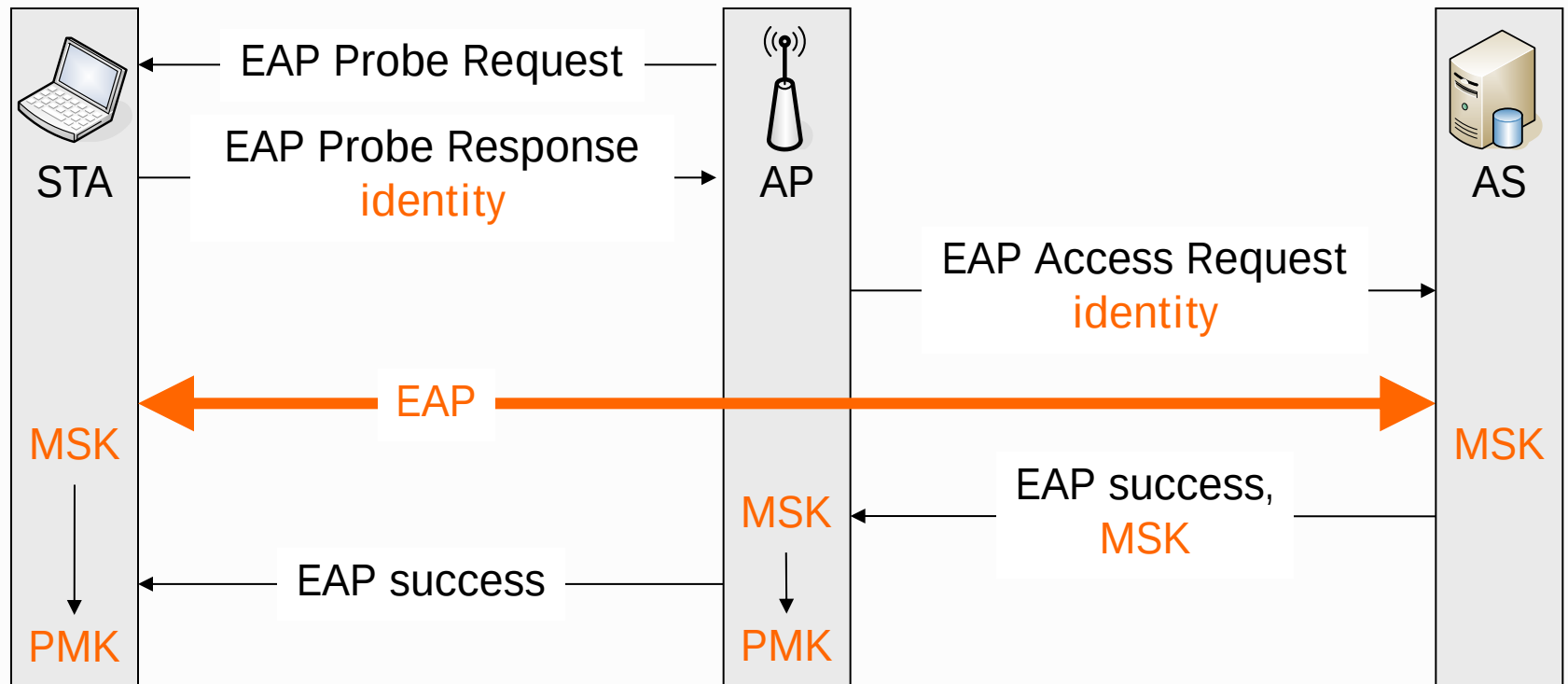
IEEE 802.1X Phase 1: Discovery (802.11 messages)



▷ STA only got access to the AP

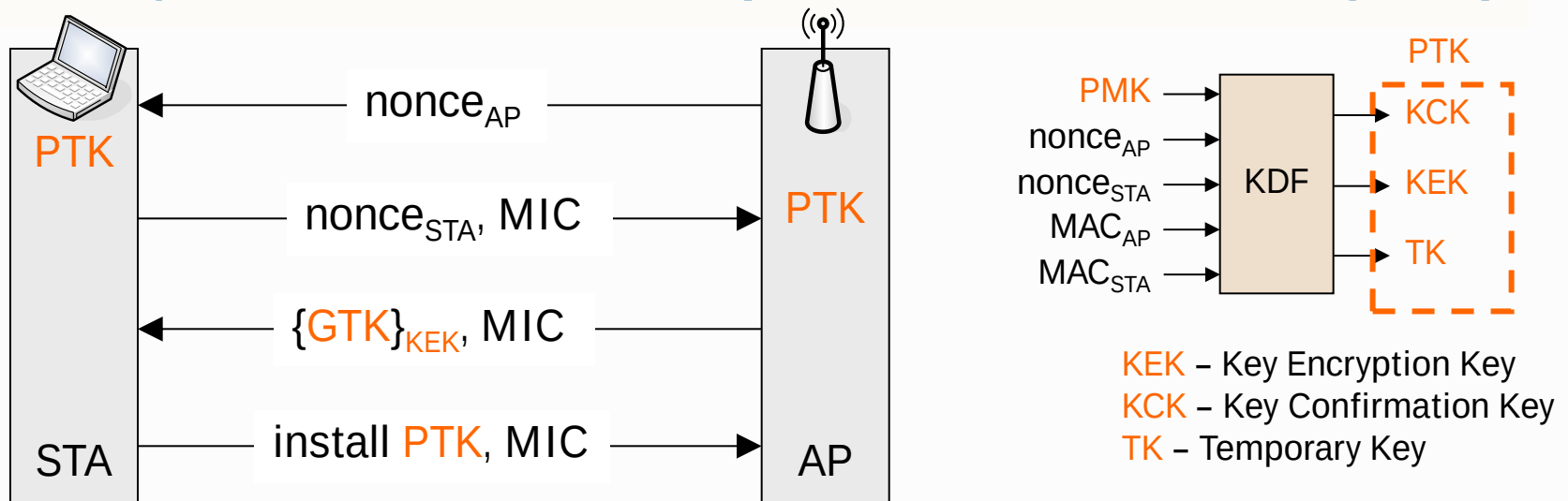
◆ 802.1X controlled port still closed

IEEE 802.1X Phase 2: Authentication (EAP Messages)



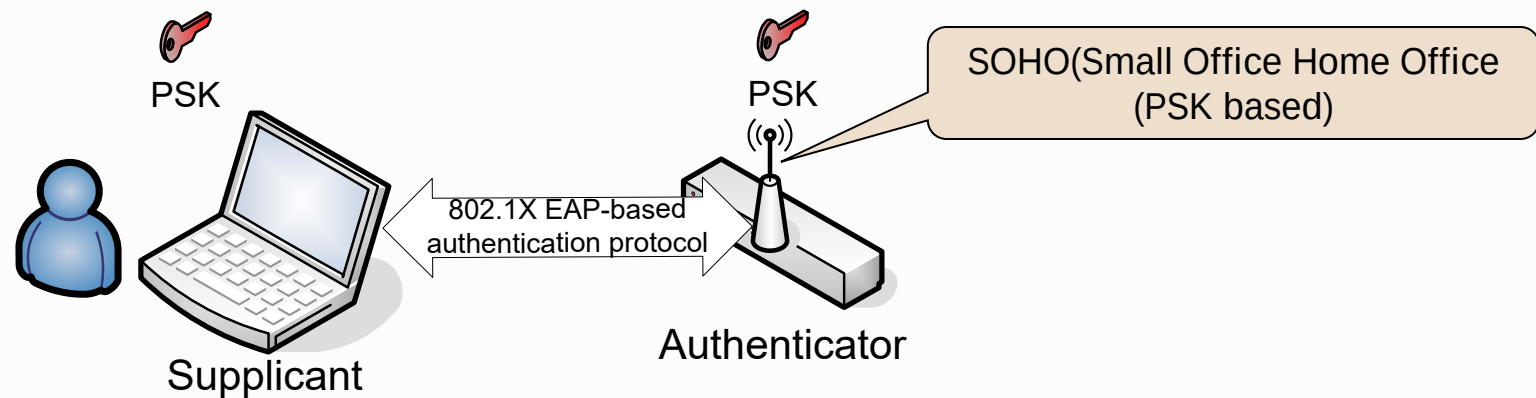
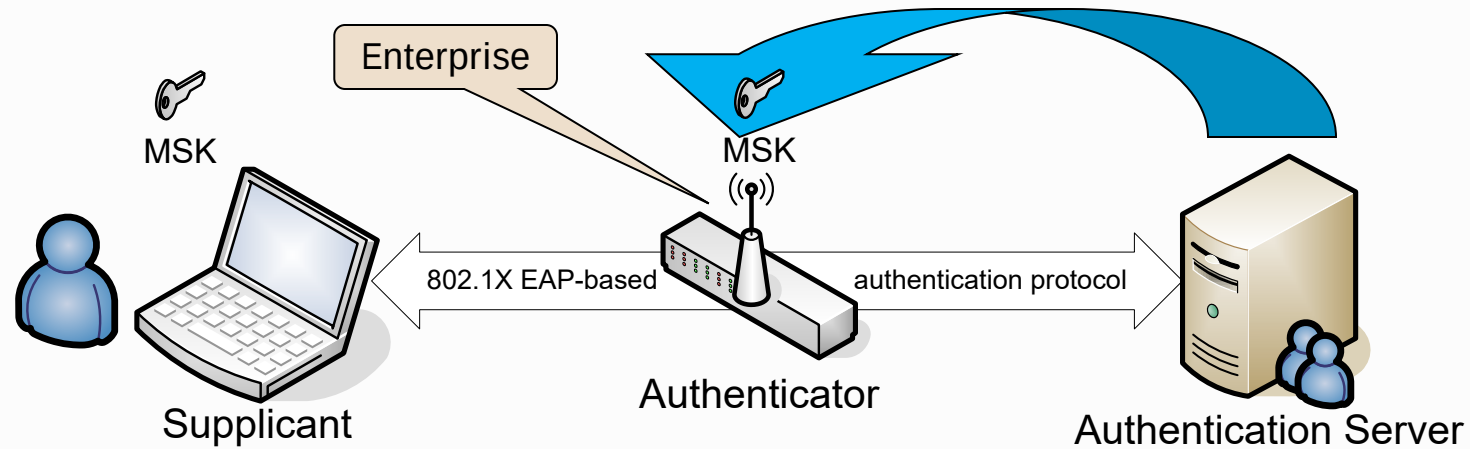
- ▶ At the end of this phase AP and STA share crypto data
 - ♦ PMK (Pairwise Master Key)
 - ♦ But 802.1X controlled port still closed

IEEE 802.1X Phase 3: 4-Way Handshake (EAPoL Messages)

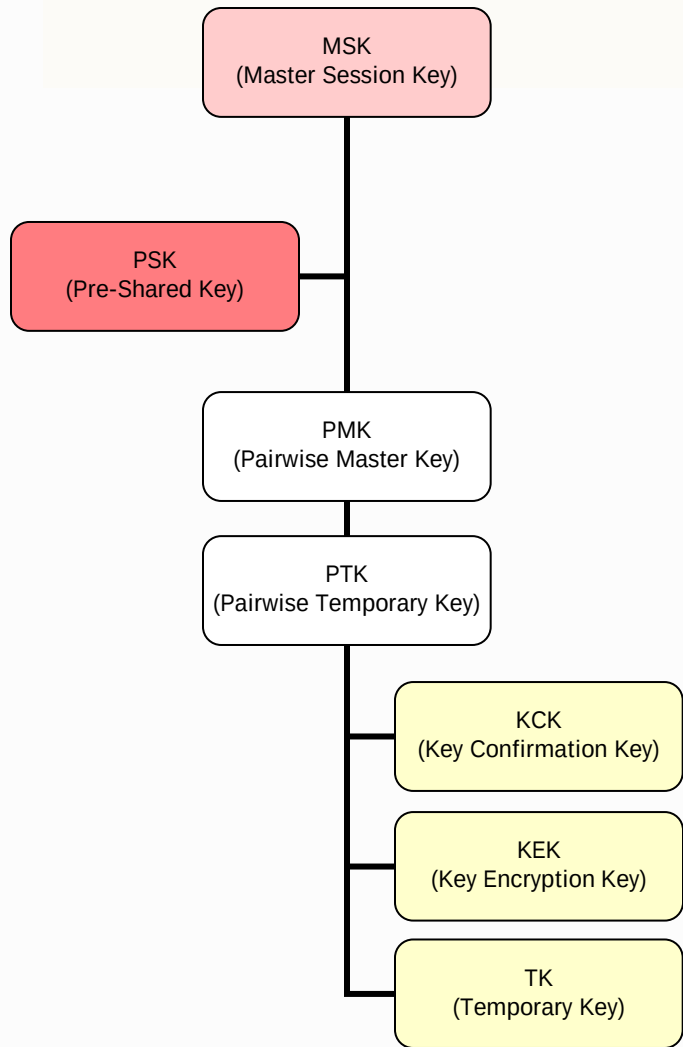


- ▶ At the end AP and STA share new, fresh crypto data
 - ♦ PTK (Pairwise Transient Key)
 - ♦ GTK (Group Transient Key)
- ▶ Both are convinced that the peer knows PMK and PTK
 - ♦ Due to the use of MICs
- ▶ 802.1X controlled port is now open for unicast traffic

IEEE 802.1X: Architectural options



IEEE 802.1X: Complete key hierarchy



▷ MSK

- ♦ Fresh outcome of an EAP protocol run
- ♦ Enterprise architecture

▷ PSK

- ♦ Long-term AP-STA pre-shared key
- ♦ SOHO architecture

▷ PMK

- ♦ Fresh key used for AP-STA mutual authentication and for key distribution in 4WH protocol runs

▷ PTK

- ♦ Key used to protect AP-STA data exchanges
- ♦ KCK / KEK: 4WH protocol
- ♦ TK: 802.11 data frames

EAP

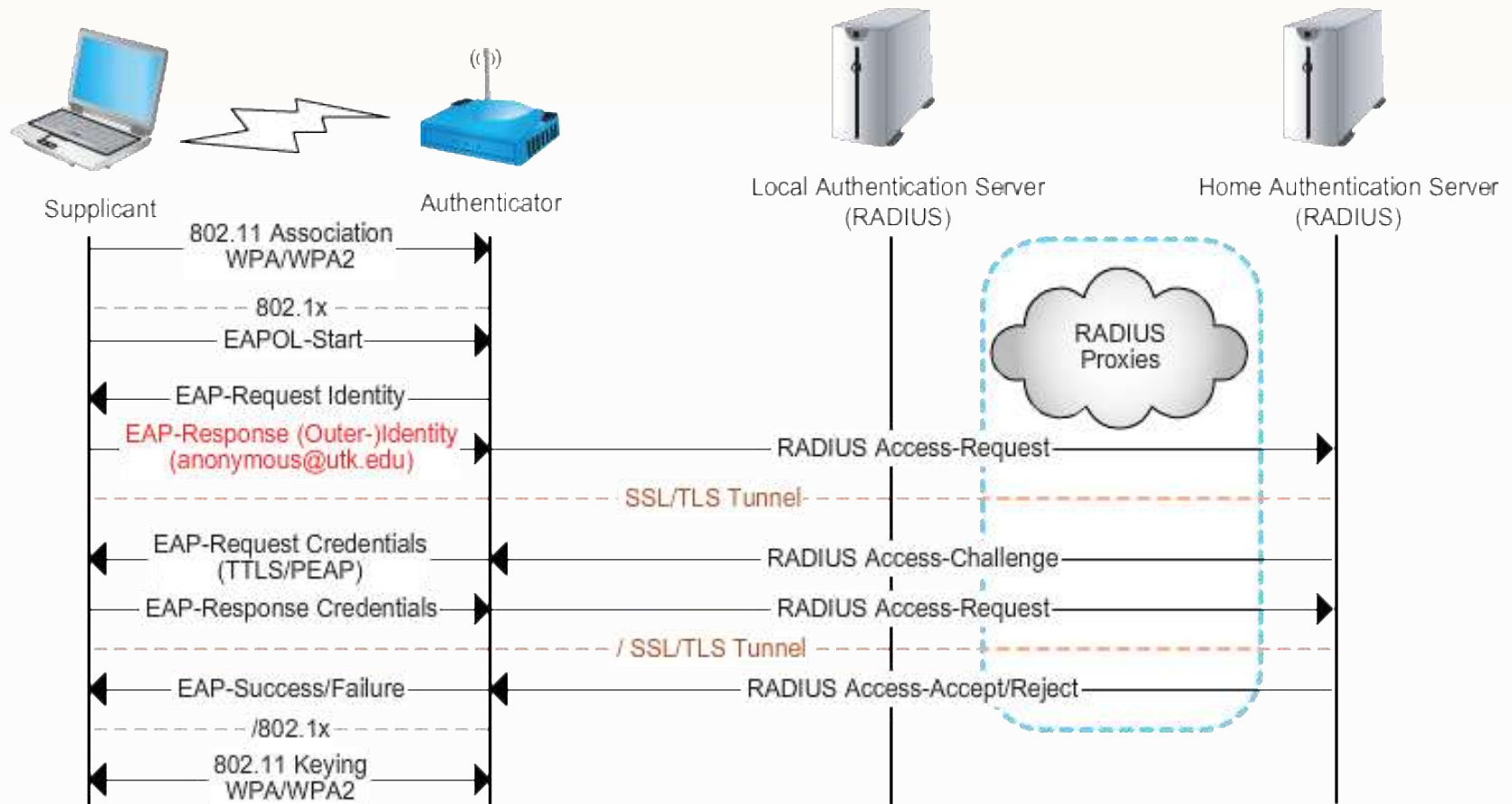
(Extensible Authentication Protocol)

- ▷ Initially conceived for PPP
 - ◆ Adapted to 802.1X
- ▷ AP not involved
 - ◆ Relay EAP traffic
 - ◆ Different EAP protocols do not imply changes in APs
- ▷ Not conceived for wireless networks
 - ◆ EAP traffic not protected
 - ◆ Mutual authentication not mandatory
 - An STA can be fooled by a stronger (radio level), rogue AP

Some EAP protocols for 802.1X

	EAP-TLS	EAP-TTLS	PEAP
AS authentication	Public Key (certificate)		
Supplicant authentication	Public Key (certificate)	EAP, Public Key (certificate)	PAP, CHAP, MS-CHAP, EAP
Risks	Identity exposure		Possible identity exposure in phase 1

Eduroam: 802.1X w/ PEAP + MS-CHAPv2



- ▶ Available on most academic facilities of the world
 - ♦ Local Authentication Servers (using RADIUS) for roaming access

802.11w:

Protected Management Frames

- ▷ Management frames that can be used for DoS attacks are authenticated
 - ◆ Forged Deauthentication & Deassociation requests
 - ◆ Other management frames unicasted or broadcast by an AP
- ▷ BIP (Broadcast Integrity Protocol)
 - ◆ IGTK (Integrity GTK)
 - ◆ For protecting part of the AP broadcast traffic
- ▷ Security Association Query Request / Response
 - ◆ Probe if the other really wants to deauthenticate or desassociate
 - ◆ Deals with desynchronization issues
 - If of of the peers crashes

IEEE 802.11 security:

Are all the problems solved? No!

- ▷ Dictionary attacks are still possible with PSK or EAP-based authentication
 - ◆ And they will continue to be as long as (weak) passwords are chosen by people

- ▷ Fake SOHO setups
 - ◆ If you know a well-known hotspot password, we can deploy a rogue AP for that hotspot
 - ◆ By doing so, you can deploy MitM attacks

WPA3

- ▷ A compliance label
 - ◆ It means that STAs support several enhanced protection techniques
- ▷ Dragonfly key agreement (SAE, Simultaneous Auth. Of Equals)
 - ◆ Alternative to the SOHO PSK key derivation
 - While still using the PSK
 - ◆ Provides secrecy of the session keys from those that know the PSK
 - ◆ Provides PFS (Perfect Forward Secrecy)
 - ◆ Prevents PSK discovery with dictionary attacks
- ▷ SOHO AP authentication with asymmetric key pair
 - ◆ No more rogue SOHO Aps
 - ◆ Clients use the public key instead of a secret PSK